

PARA O ALTO E AVANTE

IMPLEMENTAÇÃO DE UM CSIRT



14

LISTA DE FIGURAS

Figura 1 – Diversidade de tipos de incidentes enfrentados	6
Figura 2 – Mapa dos principais CSIRTs brasileiros.....	7

EMANIP

LISTA DE QUADROS

Quadro 1 – Acrônimos mais comuns para as Equipes de Respostas a Incidentes...	5
Quadro 2 – Principais serviços de um CSIRT	10

EMANIP

SUMÁRIO

1 IMPLEMENTAÇÃO DE UM CSIRT	5
1.1 Introdução	5
2 O QUE É UM CSIRT?	5
2.1 Missão do CSIRT	6
2.2 Tipos de CSIRT	8
3 SERVIÇOS.....	8
4 RECURSOS	10
4.1 Infraestrutura	10
4.2 Equipe técnica.....	11
CONCLUSÃO.....	12
REFERÊNCIAS.....	13

1 IMPLEMENTAÇÃO DE UM CSIRT

1.1 Introdução

Veremos neste capítulo como a implementação de uma Equipe de Resposta a Incidentes de Segurança – mais conhecida como **CSIRT** (acrônimo para **Computer Security Incident Response Team**) – pode auxiliar a prevenir e remediar violações de segurança nas organizações.

2 O QUE É UM CSIRT?

Como o próprio nome já diz, trata-se de uma equipe, um time composto de analistas e peritos de segurança da informação cuja principal missão é responder a incidentes de segurança. Mas não apenas isso: essa equipe presta os serviços necessários a fim de atenuar os riscos e minimizar a quantidade de respostas necessárias, que vai desde a prevenção propriamente dita à conscientização dos colaboradores (viés pedagógico).

CSIRT	Computer Security Incident Response Team
CIRC	Computer Incident Response Capability
CIRT	Computer Incident Response Team
IRC	Incident Response Center or Incident Response Capability
IRT	Incident Response Team
SERT	Security Emergency Response Team
SIRT	Security Incident Response Team

Quadro 1 – Acrônimos mais comuns para as Equipes de Respostas a Incidentes
Fonte: CertBR (2020)

A equipe de resposta a incidentes também é responsável por emitir alertas e avisos sobre as vulnerabilidades de hardwares e softwares em uso nas instituições, informando seus usuários sobre ameaças recém-descobertas ou quaisquer amea-

ças que tenham potencial danoso para os trabalhos da instituição. Ou seja: a equipe deve estar apta não apenas a remediar, mas sobretudo a prevenir violações de segurança.

2.1 Missão do CSIRT

Aqui reside uma das premissas básicas de uma equipe de resposta a incidentes de segurança: sua missão é **flexível**, pode variar muito de acordo com o setor em que está inserido. A atividade principal, o tratamento de incidentes, continua sendo a principal missão da equipe, porém o contexto muda bastante. Para demonstrar isso, usaremos dois exemplos.

Imagine um CSIRT de um departamento de polícia especializado em crimes cibernéticos. Seu foco principal será, inevitavelmente, a coleta e a análise de dados de sistemas afetados, evidências de crimes cibernéticos, análise forense etc. Por outro lado, um CSIRT de um órgão governamental de regulação pode ter seu foco principal voltado à conscientização e ao treinamento de outros órgãos e instituições subordinadas, nunca tendo que realizar atividades investigativas ou análises forenses.

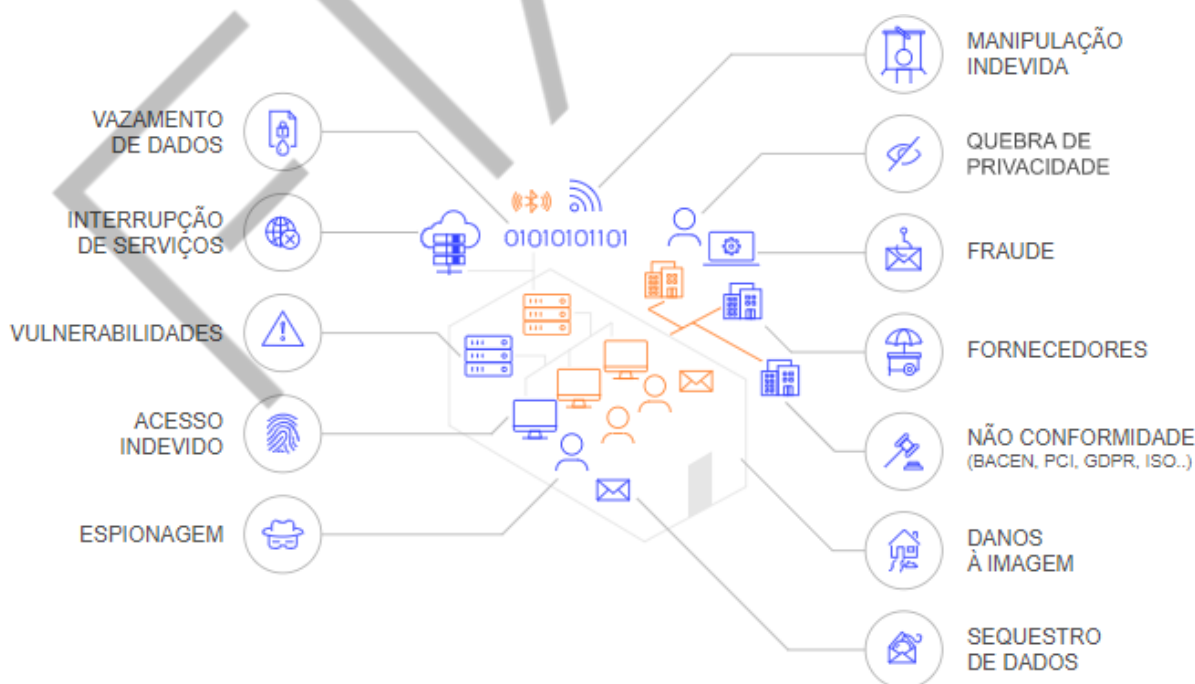


Figura 1 – Diversidade de tipos de incidentes enfrentados
Fonte: IBLISS (2021)

Fica fácil perceber, dessa forma, a flexibilidade necessária da implantação de uma Equipe de Resposta a Incidentes de Segurança da Informação. Levar em consideração o contexto, os recursos (humano e material), o papel e a missão da instituição, bem como sua localização, aspectos legais, entre outros, é essencial para o sucesso da equipe.

Saiba mais: O Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil (CERT.br) é um Grupo de Resposta a Incidentes de Segurança (CSIRT) de Responsabilidade Nacional, mantido pelo NIC.br, do Comitê Gestor da Internet no Brasil. Esse centro de estudos mantém em sua página de internet um espaço dedicado a Perguntas Frequentes (FAQ – *Frequently Asked Questions*) relacionadas a CSIRT, cujo teor é referência em todo o território nacional. Vale a pena para se aprofundar no tema: https://www.cert.br/certcc/csirts/csirt_faq-br.html.

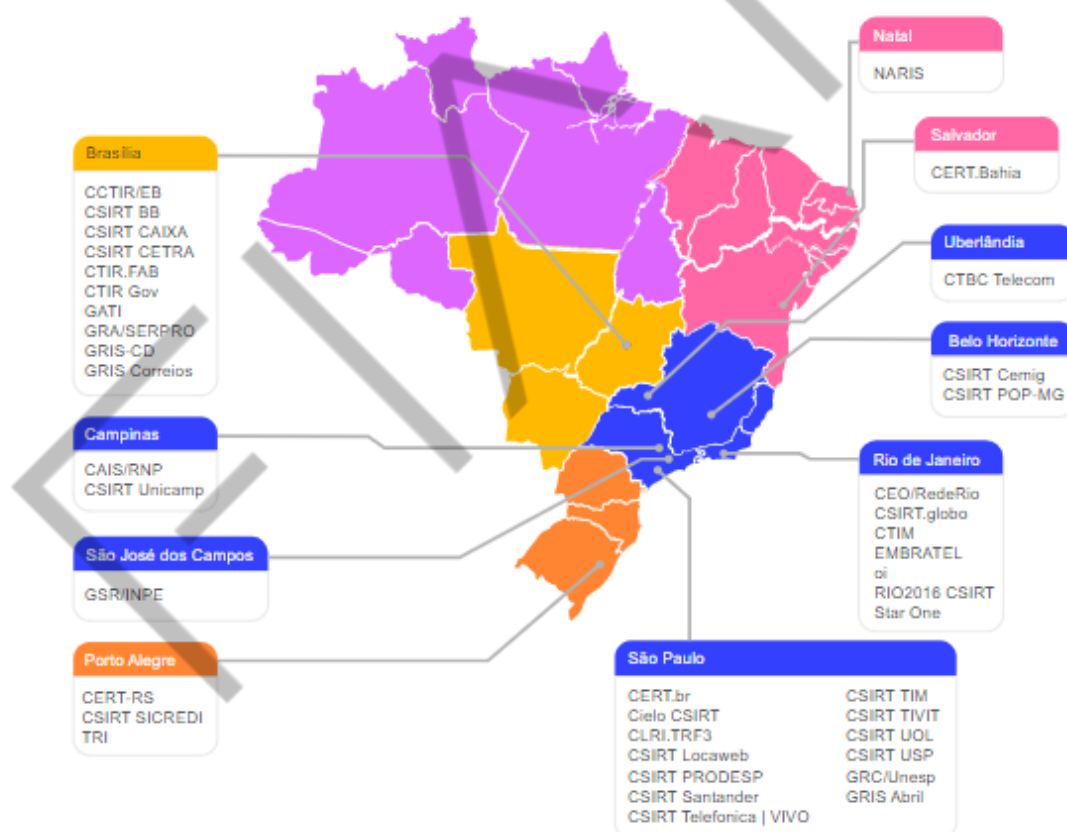


Figura 2 – Mapa dos principais CSIRTs brasileiros
Fonte: CertBR (2020)

2.2 Tipos de CSIRT

Existem vários tipos de CSIRT, pois, conforme vimos anteriormente, eles podem variar de acordo com o tipo de setor em que será instalado, os tipos de clientes que serão atendidos, quais serviços serão desenvolvidos, entre outros fatores.

Podemos observar, atualmente, os seguintes tipos de CSIRTs:

CSIRT Interno: Cujas atuação se restringe apenas à companhia onde está instalado, sendo mais uma função do que um setor. Exemplos: empresas de telefonia e bancos.

CSIRT Comercial: Oferecem seus serviços a clientes de forma comercial, normalmente cobrando taxas extras ou valores adicionais por isso. Exemplo: provedores de links de Internet.

CSIRT Governamental: Atendem a órgãos e agências governamentais de um país, ou seja: seus clientes são os cidadãos ou os próprios servidores públicos.

CSIRT Acadêmico: Seu público-alvo são os funcionários e os alunos de instituições de ensino, como centros de pesquisa, faculdades e universidades.

CSIRT Militar: Tem sua atuação voltada às organizações militares responsáveis pelo fornecimento e manutenção da infraestrutura informatizada às forças de defesa nacional e seus clientes são os próprios militares, bem como as empresas e instituições intimamente ligadas a essas organizações.

CSIRT Nacional: Possui papel central na disseminação de informações para as equipes de todo o país, sendo um intermediário em nível nacional. É o ponto de contato de segurança no país, advindo daí a sua grande importância.

3 SERVIÇOS

Quando nos referimos a serviços, devemos ter um cuidado primordial: é melhor oferecermos poucos serviços, mas bem executados. Aqui temos a mesma problemática, aplicada ao contexto da segurança da informação. O catálogo de serviços prestados deve levar em consideração vários fatores, como: conhecimento técnico necessário, recursos necessários, cenários e necessidades do negócio em que está inserida.

Esse processo de definição dos serviços que serão providos nem sempre é uma tarefa fácil, pois envolve não apenas os fatores citados anteriormente, mas também a forma como serão prestados, tendo em vista o entrosamento da equipe, a curva de conhecimento e o crescente ganho de confiança das equipes perante seus clientes etc. Resumindo: definir os serviços de forma realista e honesta é essencial para o seu sucesso.

Quanto às **categorias** de serviços, há diversos serviços que um CSIRT pode oferecer, a depender do tipo de cliente e do objetivo. Dessa forma, podemos agrupar os serviços de um CSIRT nas seguintes categorias:

Serviços proativos: Esse tipo de serviço tem como objetivo fornecer informações e assistência necessárias que garantam a segurança dos sistemas e computadores de uma instituição por meio da prevenção, se antecipando a ataques, eventos ou incidentes.

Serviços reativos: Esse tipo de serviço constitui o “core” de uma equipe de resposta a incidentes. São normalmente acionados por uma requisição ocasionada por um evento/incidente, cujo teor pode ir de um vírus de computador a um ataque mais complexo identificado por ferramentas de IDS/IPS, em que serão utilizados relatórios de análise de vulnerabilidades, sistemas de armazenamento e análise de logs, entre outras ferramentas.

Serviços de gerenciamento de qualidade da segurança: A participação da equipe de respostas nesse tipo de serviço, trabalhando em conjunto com equipes já estabelecidas de auditoria e controle internos, amplia a visão acerca do nível de segurança dentro da instituição, oferecendo um ponto de vista acurado, diminuindo a exposição a riscos e ameaças desnecessárias.

Serviços reativos	Serviços proativos	Serviços de gerenciamento de qualidade de segurança
- Alertas e informativos - Tratamento de incidentes - Análise de incidentes - Resposta à análise de incidente - Tratamento de vulnerabilidades - Análise de vulnerabilidades - Resposta à análise de vulnerabilidades - Tratamento de artefatos - Análise de artefatos - Resposta à análise de artefatos	- Comunicados - Estudos de novas tecnologias - Inventário e auditorias de segurança - Configuração e manutenção de ferramentas de segurança, aplicações ou infraestruturas - Desenvolvimento de ferramentas de segurança - Sistemas de detecção de intrusão - Disseminação de informação relacionada à segurança	- Análise de risco - Plano de continuidade de negócios - Plano de recuperação - Consultoria de segurança - Conscientização interna - Educação / Treinamento - Certificação ou avaliação de produtos

Quadro 2 – Principais serviços de um CSIRT
Fonte: CertBR (2020)

4 RECURSOS

Para que tais atribuições sejam possíveis, devemos pensar em dois recursos fundamentais: infraestrutura e equipe técnica. As duas seguem juntas e devem ser motivo de preocupação constante: seja por atualizações na infraestrutura, seja por capacitação da equipe. Fato é que a sinergia deve ser no sentido de fortalecer a instituição, numa confluência de esforços nesse sentido.

4.1 Infraestrutura

As infraestruturas físicas e lógicas da rede devem refletir a preocupação com a segurança e a proteção dos dados sensíveis da companhia. O acesso por parte das equipes deve ser rigoroso e controlado, e todas as precauções conhecidas e viáveis (física e financeiramente) devem ser tomadas.

As equipes devem ter acesso a laboratórios para realização de testes, equipamentos para análise de vulnerabilidades e sistemas e softwares de armazenamento e análise de logs, por exemplo. Apesar do custo elevado, é altamente recomendável a disponibilização de uma infraestrutura de suporte dedicada à operação do CSIRT (alternativa à rede principal da organização), cujo escopo deve contemplar, entre outros:

- Um sistema de acesso remoto seguro;
- Uma rede separada para o CSIRT;
- Ferramentas para análise e armazenamento de logs;
- Sistemas de videoconferência;
- Padronização dos métodos e cronograma de atualizações e instalações de *patches*;
- Rede apartada da principal e dispositivos para testes em laboratório;
- Serviços e sistemas separados e dedicados (links, e-mail, ambiente web, DNS, Proxy e outros).

4.2 Equipe técnica

A equipe técnica, por sua vez, deve ser composta de profissionais com grande variedade de habilidades técnicas e emocionais, pois enfrentarão situações estressantes e terão de saber trabalhar sob pressão, ocasiões estas que evidenciam certos atributos desses profissionais, como flexibilidade, dedicação, inovação, comunicação e espírito de equipe. A composição e o entrosamento da equipe são fundamentais para o sucesso do CSIRT. Vale ressaltar a necessidade de continuidade da equipe, sem grandes alterações no decorrer do tempo que gerem sensação de instabilidade profissional, e investimentos em formação continuada dos profissionais que a compõem (levando em conta também a chamada “curva de conhecimento”).

Algumas habilidades técnicas e emocionais importantes:

Pessoais: Habilidades comunicativas e de inter-relacionamento, flexibilidade e controle emocional.

Técnicas: Experiência em plataformas Unix, Mac e Windows, bem como administração de redes e sistemas; entendimento sobre protocolos de internet, vulnerabilidades e ataques mais comuns.

Treinamento em segurança: Experiência em resolução de problemas, tratamento de incidentes, habilidades de análise (forense e de malware) e pensamento crítico, conhecimento em ameaças cibernéticas e técnicas de ataque e exploração.

CONCLUSÃO

Neste capítulo, podemos perceber que as atividades desenvolvidas por um CSIRT têm importância fundamental para as organizações, não apenas durante o ciclo de vida do incidente, mas também no clima de segurança que repercute em todas as esferas dessas organizações. Os recursos humanos e materiais devem ser priorizados e valorizados pela direção dessas organizações, tendo em vista o grau de permeabilidade dos incidentes no ambiente de negócios das instituições.

Os conceitos, metodologias, processos e modelos são bastante difundidos e variam muito, pois levam em conta diversos fatores, todos muito específicos, tornando cada CSIRT uma equipe única, cujos valores e habilidades serão igualmente únicos na medida em que são valorizados e incentivados, não apenas com aperfeiçoamento, mas também oferecendo um ambiente favorável que os prepare para os momentos de pressão e estresse. Afinal de contas, o que todos esperam em um momento de incidente real de segurança da informação é que ele seja breve e que não volte a acontecer.

REFERÊNCIAS

CERT.BR. **CSIRT FAQ**. 2004. Disponível em: <https://www.cert.br/certcc/csirts/csirt_faq-br.html>. Acesso em: 13 jun. 2024.

DURBANO, V. **CSIRT: o que são os grupos de Resposta a Incidente de Segurança?** 2019. Disponível em: <<https://blog.ecoit.com.br/csirt-o-que-sao-os-grupos-de-resposta-incidente-de-seguranca/>>. Acesso em: 13 jun. 2024.

ENISA. **Abordagem gradual de criação de uma CSIRT**. 2010. Disponível em: <<https://www.enisa.europa.eu/publications/csirt-setting-up-guide-in-portuguese>>. Acesso em: 13 jun. 2024.

IBLISS. **Como está a segurança cibernética de sua empresa agora?** 2021. Disponível em: <<https://www.ibliss.com.br/>>. Acesso em: 13 jun. 2024.

ISO. **IEC 27035 – 1:2016 – Principles of Incident Management**. 2016. Disponível em: <[ISO/IEC 27035-1:2023 - Information technology — Information security incident management — Part 1: Principles and process](#)>. Acesso em: 13 jun. 2024.

ITIL. **IT Service Management**. Disponível em: <<https://www.axelos.com/best-practice-solutions/itil>>. Acesso em: 13 jun. 2024.

PINTO, R. **A implantação de uma equipe de resposta a incidentes de segurança em uma instituição de ensino**. Especialização (Pós-graduação Lato Sensu em Rede de Computadores com Ênfase em Segurança). Centro Universitário de Brasília, Instituto CEUB de Pesquisa e Desenvolvimento – ICPD. Brasília, 2017. Disponível em: <<https://repositorio.uniceub.br/jspui/bitstream/235/12407/1/51600262.pdf>>. Acesso em: 13 jun. 2024.